Política de contraseñas (guía para usuarios)

Al registrarse, al cambiar la contraseña, al restablecerla y cuando un administrador crea un usuario, el sistema aplica la misma política. Su objetivo es evitar contraseñas débiles o que contengan datos personales.

Requisitos que debe cumplir tu contraseña

Regla	Valor
Longitud mínima	**10 caracteres**
Longitud máxima	**72 bytes** en UTF-8 (límite de bcrypt)
Espacios	**no se permiten**
Composición	al menos **una mayúscula**, **una minúscula**, **un número** y **un símbolo**
Contraseñas comunes	se rechazan las de una lista de **200** contraseñas frecuentes (comparación en minúsculas)
Datos personales	no puede contener tu **correo**, **nombre**, **apellido** ni **identificación**

La comparación de datos personales normaliza acentos y mayúsculas: cualquier parte del correo (incluido lo que va antes de `@`), del nombre o del apellido con **4 o más caracteres** normalizados que aparezca en la contraseña hace que se rechace; la identificación normalizada completa también se rechaza. El mensaje de error es `La contraseña no puede contener el correo, el nombre, el apellido ni la identificación`.

Las contraseñas se almacenan con **bcrypt** (`hash_password` / `verify_password`), nunca en texto plano. El administrador inicial se valida con la misma política (`validar_password_admin`).

Cambiar la contraseña

`POST /auth/cambiar-password` requiere sesión y es **solo POST** (no existe un `GET` de ese recurso). Cuerpo:

```
{ "passwordActual": "...", "nuevaPassword": "..." }
```

El servicio verifica la actual con bcrypt, exige que la nueva sea **distinta** de la actual (`La nueva contraseña debe ser diferente a la actual.`) y aplica la política. Responde **200** con `Contraseña actualizada correctamente.` o **400** con el motivo en `errors`. No tiene un limitador de intentos dedicado.

Recuperar la contraseña

• `POST /auth/forgot-password` devuelve **siempre la misma respuesta**, exista o no el correo (anti-enumeración), y envía el correo en segundo plano.
• El token se genera con `secrets.token_urlsafe(32)` y se guarda **hasheado con SHA-256** (el plano solo viaja en el correo).
• Es **de un solo uso** (`utilizado`) y expira a los **30 minutos**.
• `POST /auth/reset-password` recibe `{"token", "nuevaPassword"}` y valida el token, que no esté usado, que no haya expirado y la política.

Límites de intentos de login (429)

Limitadores en memoria, por proceso, con ventana deslizante y tope global de **10 000 claves** por limitador:

Ámbito	Límite	Ventana	Bloqueo
Login por pareja correo+IP	**5** fallos	15 min	**15 min**
Login por correo	**15** fallos	15 min	—
Login por IP	**100** fallos	15 min	**15 min**
Registro por IP / correo	10 / 5 solicitudes	60 min	—
Recuperación por IP / correo	10 / 3 solicitudes	15 min	—
Restablecimiento por IP / token	10 / 5 solicitudes	15 min	—

Un login correcto limpia **solo** el contador de la pareja correo+IP; los de correo e IP se conservan. La respuesta **429** incluye la cabecera `Retry-After` en segundos. Mensajes: `Demasiados intentos fallidos. Intenta de nuevo en 15 minutos.` y `Demasiadas solicitudes. Intenta de nuevo más tarde.`

Duración de los tokens

• **JWT de usuario**: **HS256**, expira a los **30 minutos** (`JWT_EXPIRATION_MINUTES`). Claims: `sub`, `uid`, `rol`, `modulos`, `iat`, `exp`. `decode_token` exige `exp/sub/uid/rol` y rechaza tokens con rol `SERVICIO` o `uid = 0` en endpoints de usuario.
• **Token de recuperación**: **30 minutos**, un solo uso, hasheado con SHA-256.
• **Token interno de servicio** (solo para `POST /correos`): **5 minutos**, rol `SERVICIO`, mismo `JWT_SECRET`.

Consecuencias prácticas

Para que tu contraseña sea aceptada, combina los cuatro tipos de caracteres, usa 10 o más caracteres, evita espacios y no incluyas tu correo, tu nombre, tu

apellido ni tu número de identificación. No reutilices contraseñas de la lista de contraseñas comunes.